Monthly Intelligence Dispatch

October 2017

The Group-IB Monthly Threat Intelligence Dispatch is a monthly overview of current cyberthreats and new incidents – attacks of criminal groups, leaks and new malware. This report includes short term forecasts and warnings, which will allow you to take timely measures to protect yourself against cyberthreats. This dispatch is for official use only!

Key Conclusions

- The BadRabbit ransomware attack on October 24, 2017 and the outbreak of NotPetya, which attacked power, telecommunication and financial companies in Ukraine in June 2017, were performed by the same hacker group – BlackEnergy.
- BlackEnergy was purportedly also behind an attack on Japanese banks, which started at least in March 2017. The attack was conducted using the Ammyy Admin RAT and ONI ransomware.
- Lazarus, a hacking group linked to North Korea, has turned out to be one of the main suspects of a targeted attack on Taiwan's Far Eastern International Bank. As a result of the attack on SWIFT, the hackers managed to withdraw about $60 million.
- The MoneyTaker hacker group has become active in Russia and now its main focus is bank card processing.
- The state-backed group called APT28 is attacking not only aerospace enterprises, but also possible participants of CyCon, the NATO conference for cybersecurity.
- Currently, there are no new banking Trojans attacking users in Russia that have appeared during the last year. This situation may change with the emergence of a banking bot called Dented.
- Information published on the KRACK vulnerabilities in implementations of all WPA2 protocols has caused an active discussion on underground forums: hackers have actively been discussing the practical application of WPA2 vulnerabilities in attacks on end users.

Main Events: Ransomware

BadRabbit/ BlackEnergy

The main event in October was undoubtedly the attack of **BadRabbit** ransomware on October 24. BadRabbit's distribution was large-scale, although there were far fewer victims than in the case with NotPetya in June 2017. The BadRabbit attack affected Odessa airport, the Kiev metro and government institutions in Ukraine, as well as editorial offices of some federal media in Russia; there were also attempts to attack banks, but they were unsuccessful. The malware was distributed via hacked popular Internet resources in Ukraine and Russia. BadRabbit was distributed using the drive-by download method, and the attack was planned carefully – the website which distributed the malware had been prepared on October 19, while some modules were compiled in the summer of 2014 and used in previous attacks. The Group-IB investigation has proved that the BadRabbit code was compiled from NotPetya sources and these attacks were performed by the same group. Despite the fact that the attackers tried to disguise themselves as criminal extortionists, the investigation shows that the attack was probably performed by state-backed hackers from the BlackEnergy group known for its attacks on the Ukrainian power, financial and transport systems.

ONI/BlackEnergy

Group-IB has detected a targeted attack against Japanese banks, which has lasted at least since March 2017. The attack is being conducted using the Ammyy Admin utility and ONI ransomware. In late October, Cybereason published a report stating that they had investigated an attack of the ONI/MBR-ONI ransomware against Japanese companies and found out that infection with this ransomware had been the result of a long-lasting and sophisticated attack. Group-IB specialists suppose that the attack was also performed by the BlackEnergy group. In their attacks against Japan, as with those against Ukraine, the hackers did not use the self-distribution mechanism. As with attacks in Ukraine in February, and then in the NotPetya and BadRabbit attacks, in Japan the attackers used ransomware that modified the MBR. The ONI ransomware used in attacks against Japan included the DiskCryptor source code, which was later used in NotPetya and BadRabbit. And finally we detected the use of the Russian language in the ONI ransomware code (ONI is 'the devil' in Japanese). We suppose that similar attacks may also be detected in other countries.

Main Events: Targeted Attacks

Toplel

A criminal group called Toplel, which was actively attacking customers of Russian and Ukrainian banks three years ago, has returned to the spotlight and renewed its attacks on Russian companies and banks. The malware is distributed via bulk emails with a malicious attachment – the Symmi backdoor. In order to collect the authentication data (logins, passwords) from various systems, the hackers are still using Pony malware. The Toplel group was first detected by Group-IB specialists in February 2015 – it turned out that it had been active at least since August 2014 and had used domain names registered in the .SU zone. At that time, the hackers used a Trojan called RDPdoor (xTerm), which granted remote access to computers. The attackers were able to conduct transactions from users' workstations, when a token with an electronic digital signature required to approve transactions was connected. The attacks were mainly focused on customers of Russian and Ukrainian banks.

Lazarus

While Toplel is searching for ways to attack bank customers, another group has managed to rob Taiwan's Far Eastern International Bank itself. It is very likely that this attack was performed by the North Korean hackers from the Lazarus group. These conclusions have been made by researchers from Group-IB, BAE Systems and McAfee independently of each other. When the hackers got to the bank's SWIFT system, they managed to withdraw almost $60 million to accounts in Sri Lanka, Cambodia and the US. In Sri Lanka, the police blocked three accounts with a total of $1.3 million and on October 8 detained two men who tried to take out money in a bank. After analyzing some sample hashes related to the incident, Group-IB specialists have concluded that the msmpeng.exe and splwow32.exe files were a unique utility called Client_TrafficForwarder and previously used by the Lazarus group (for details see the report: https://www.group-ib.com/lazarus.html). In addition to using the malware previously detected in the Lazarus attacks in Poland and Mexico, the involvement of the North Korean hackers is demonstrated by the fact that the money was withdrawn to accounts in Sri Lanka and Cambodia – both countries were previously used by Lazarus for withdrawing funds and converting them into cash. And second, the tracks were covered up with Hermes ransomware and previously tried-and-tested attack methods. It was Lazarus that performed the WannaCry ransomware outbreak in May 2017, although the North Korean authorities formally deny this fact.

Main Events: Targeted Attacks

MoneyTaker

A hacker group called MoneyTaker, which has organized a new targeted cyberattack on banks, is now focused on card processing. In late October, it was reported that a group of hackers were conducting targeted attacks on banks. According to Group-IB, it is MoneyTaker aka Fin7, a Russian-speaking criminal group, which is specialized in targeted attacks on financial institutions all over the world. Recently, it has focused its efforts on small North American banks and switched to card processing (the card processing system is not as well protected as SWIFT). We provided our Intelligence service customers with detailed information on MoneyTaker last year. The peak of MoneyTaker's activity was observed in late 2016, when it actively attacked banks in Russia, Hong Kong, and the US. The group has already conducted a successful attack on the AWS CBC (Automated Working Station of the Russian Central Bank Client). Hackers break into corporate networks by using targeted emails with malicious files sent under the name of financial organizations or by compromising networks belonging to providers who render services to financial institutions. This spring, Group-IB specialists tracked 13 successful targeted attacks conducted by MoneyTaker. Cybercriminals have compromised corporate networks, and in some cases gained access to confidential documents related to SWIFT, card processing, ATM control systems and other highly sensitive information of banks' VIP customers. Victims may not even suspect that they have been attacked.

Ursnif aka Gozi

According to a report prepared by researchers from IBM X-Force, a banking Trojan called Ursnif aka Gozi has become active in Japan. According to experts, in addition to banks, a new version of Ursnif is focused on login credentials belonging to users of local webmail, cloud storages, cryptocurrency exchange platforms and online shops. Ursnif was first tracked in 2007, and two years later its source code appeared on hacker forums, which resulted in the malware being spread and new features emerging. Ursnif-2 used webinjects and included the hidden remote administration function. By the end of 2010, Ursnif had attacked an impressive number of banks in Europe, the UK and the US. According to X-Force, in 2017, in addition to Japan, the US and Australia, Ursnif is threatening banks in Bulgaria, Poland, Spain and the Czech Republic.

Main Events: Espionage and Botnets

APT28

In October, the APT28 group, which many researchers link to Russia, was again mentioned in report headlines. Proofpoint researchers have found out that while sending malicious attachments, APT28 used a "zero-day" vulnerability called CVE-2017-11292 (updated Adobe Flash). According to the experts, the state-backed hackers have focused their attacks on government authorities and private sector enterprises working in the aerospace industry across Europe and in the US. According to Cisco Talos researchers, one more vector of the APT28 attack was focused on participants of the NATO cybersecurity conference. The CyCon conference organized by the NATO Cooperative Cyber Defence Centre of Excellence (CCDCOE) in cooperation with the Army Cyber Institute at West Point will be held on November 7-8 in Washington D.C. According to Cisco Talos, the state-backed hackers sent fake invitations to CyCon to specialists in cybersecurity in emails with malicious attachments designed for spying.

Botnets

Check Point researchers have found a new large-scale IoT bot, which first appeared in September 2017. The malicious code is trying to use many known vulnerabilities in various models of IP cameras, including GoAhead, D-Link, TP-Link, AVTECH, NETGEAR, MikroTik, Linksys and Synology. According to the experts, the malware has already infected more than a million devices all over the world and 60% of victims were included in corporate networks. In last year‘s report we mentioned the returning popularity of botnets for DDoS attacks, however they are not created on Windows-run PCs, but on simple IoT (Internet of Things) devices. Such botnets are becoming quite large (the Mirai botnet included 400,000-500,000 infected devices) and the life cycle of each bot is much longer than that of any Windows Trojan. In order to build botnets, attackers use the password attack method or certain vulnerabilities, as in the above mentioned case with the hacking of video cameras.

Main Events: ICO and SmartVista

Etherparty

In our recent report, we warned that attacks on ICOs were one of the most dangerous trends. Quick, and often simple attacks can bring hundreds of thousands to criminals with minimum risk to them. We are continuing to track new attacks every month. On October 1, Etherparty, a platform for automatically creating smart contracts, launched an ICO (initial coin offering) procedure and was attacked by hackers almost immediately. The hackers posted their own address on the resource, which meant that investors were sending money directly to their wallet. The Etherparty administration detected the attack 15 minutes after the hacking and blocked the website for an hour and a half, in order to stop investors sending money to the fraudsters. The company promised to compensate for losses. Hackers often use vulnerabilities in platforms to steal money. The CoinDash investment portfolio management platform lost over $6,000,000 during the first 3 minutes after the start of an ICO due to a vulnerability in the website code – criminals had replaced the number of a wallet where the money was being sent to.

SmartVista

The US CERT Coordination Center and SwissCERT have published a warning about vulnerabilities in the SmartVista processing platform (a BPC Banking product), which may result in the leakage of users' data. These problems allowing the injection of SQL codes have been found by Rapid7 experts. An attacker with access to the SmartVista Front-End interface can exploit vulnerabilities and obtain information stored in the server database, including usernames and database passwords. For example, the Transactions page in the Customer Service section of the SmartVista Front-End interface allows users to view the data on transactions connected with particular cards or accounts. This vulnerability is characterized as CWE-89 (improper neutralization of special elements used in SQL commands).

Main Events: Infrastructure

KRACK

Information security specialists have long since been warning people about the dangers of using Wi-Fi in public places. It is now clear that users of absolutely all Wi-Fi access points are under threat. On October 16, there were reports of a series of vulnerabilities called KRACK in implementations of all WPA2 (Wi-Fi Protected Access 2) protocols. The danger is that attacks using these vulnerabilities allow traffic to be intercepted and decrypted between a Wi-Fi access point and a client. It is enough to be in a stable signal zone for that to happen. Information published on the vulnerabilities has caused lively discussions on underground forums: users interested in wardriving have actively been discussing the practical application of WPA2 vulnerabilities in attacks on end users. There was a risk that after information was published on the vulnerabilities and the Proof-of-Concept exploit it would be adapted for attacks on end users. However, in order to make an attack impossible, all that needs to be done is to apply corrections either with at the client end or at the access point. Some manufacturers of vulnerable devices have already released firmware to address these vulnerabilities. On October 18, 2017, researchers published a script allowing us to determine if an access point is vulnerable to Key Reinstallation attacks (https://github.com/vanhoefm/krackattacks-test-ap-ft).

DDE

On October 9, 2017, Sensepost published an article called "Macro-less Code Exec in MSWord" describing a method for malicious code execution in Microsoft Office products. This is about DDE technology, which is not a macro. DDE is an outdated mechanism for the interaction of applications in Windows operating systems. This mechanism is still supported in new versions of Windows, but it has long been replaced by its analogues – OLE, COM. It serves for on-line data transmission and synchronization in applications. This mechanism can run any program with required parameters while opening Microsoft Office documents with the DDEAUTO field. For example, it may be PowerShell with a malicious script, which will download some malware from the web and run it. But according to Microsoft's specialists, this mechanism is not a vulnerability. The above mentioned opportunity is offered by a message exchange protocol in MS DDE products and this technique is available in all MS Office products such as Word, Excel, etc.

Main Events: Banking Trojans

AhMyth Android RAT

In our annual report we warned about a new trend – many malicious code developers have increasingly started to make the source codes of their programs publicly accessible. The events of this autumn show that our forecast is coming true. In October, the GitHub forum published a source code of a new Android Remote Administration Tool – it is called AhMyth Android RAT. ESET researchers have detected the presence of this malware on the Internet. In the last 12 months, they have published source codes of a banking Trojan for personal computers called **TinyNuke**, a banking Android Trojan called **Maza-in, RATAttack** using a protected Telegram channel, a DDos Trojan called **Mirai** and various ransomware programs.

Dented

In Russia, since mid-2012, we have been observing the constant reduction of damage caused by banking Trojans for personal computers. Until recently, only one criminal group – Proxy – attacked individuals using banking Trojans for personal computers. From April 2017, they stopped attacks in Russia and there have been no new banking Trojans attacking users in Russia during the last year. However, this may be just a lull. One of the underground forums has published an advertisement offering a source code of a banking bot called Dented. The seller nicknamed Refreshers, who was earlier engaged in the development of POS malware and cryptoware, claims that this bot has been written from scratch in C language and is not based on the publicly available tinynuke source codes. The banking Trojan allows criminals to override infected computers and steal logins/passwords, bank card details and money from accounts. The owner is ready to sell the Trojan to three clients for $3000 each. There is no information as to whether it will be prevented from working in Russia.

Hidden VNC Blowbot

Another underground forum has published an advertisement offering a hidden VNC malware program written by a hacker nicknamed Neoz11. The malware works on all versions of Windows OS and allows attackers to gain remote access to victims' computers: access to files and folders, execution of tasks/commands, control using the administration panel. The program is priced at $550 for the first 10 buyers and $750 for others. Support is $100 per month.

Extraditions

Pyotr Levashov

In October, Spain and Greece extradited to the US two prominent figures from the cybercrime world – the Russian "spam king" Pyotr Levashov (Peter Severa) and Alexander Vinnik, the co-founder of BTC-e, one of the oldest cryptocurrency exchanges. The 36-year-old Russian citizen Pyotr Levashov (aka Peter Severa) has been included in the list of "10 World's Worst Spammers" by the Spamhaus Project. Brian Krebs, the author of "Spam Nation", named Levashov the spammers' "concierge" and an organizer of his own spam networks. Officially, Levashov is charged with creating a botnet – a network of infected computers that can be controlled remotely, without the knowledge of their owners. The botnet attributed to Levashov is known as Kelihos (Hilux) or Waledac 2.0 (named after its previous version). In 2012, Crowdstrike found 110,000 computers caught in its nets. Spamhaus reports that Severa was a partner of the US spammer Alan Ralsky, who served a 4-year prison sentence for fraud. This April, Levashov and his family arrived in Barcelona on holiday and he was detained there by the local special forces upon the request of the US Department of Justice.

Alexander Vinnik

The US Department of Justice is charging 38-year-old Alexander Vinnik with fraud and laundering of $4 billion via bitcoin transactions. According to the US authorities, Vinnik might be linked to the money lost in 2014 after the bankruptcy of the crypto-currency exchange Mt.Gox. **Three years ago, this exchange, which held 70% of all the global bitcoin trade, was attacked by hackers who stole 850,000 bitcoins (about $500 million).** The FBI started to monitor Vinnik in May 2016, when he was in Abu Dhabi, but he was only arrested in 2017, in the Greek city of Thessaloniki.

Forecasts and Warnings

- In October, the MoneyTaker group took steps to break into banks. During November, they will probably implement several successful attacks on Russian and CIS banks. They will be mostly focused on interbank transfer systems and ATMs.
- The Cobalt group has reduced its activities in Russia and the CIS, which may indicate that they are focusing their efforts on larger targets. In November, they will be able to implement attacks via compromised card processing that are currently being prepared, causing major damage. We have tracked their attempts to attack banks in Mexico and Saudi Arabia.
- We are tracking increased activity of the Toplel group, including attempts to infect banks. We believe that this may lead to a rise in the number of thefts from entities via online banking systems; targeted attacks on banks are also possible.
- The intensity of DDoS attacks will also increase, due to the emergence of the new IoT botnet.

If you wish to receive more detailed information about a specific incident, threat or criminal group:

Please contact us.

We can conduct investigations to give you the maximum intelligence on the threats targeting your organization.

+1 917 809 47 41
+7 495 984 33 64
intelligence@group-ib.com